

1. Current Attacks

In April, the Play ransomware group exploited a zero-day vulnerability in the Windows Common Log File System (CLFS), known as CVE-2025-29824. This vulnerability allowed local attackers to escalate privileges to system level. Using this flaw, the attackers deployed PipeMagic, a loader that enabled further execution of Play ransomware and related malware across the network.

Zero-day Exploit (CVE-2025-29824)

A use-after-free flaw in `clfs.sys` allowed creation of a malformed CLFS handle, triggering privilege escalation.

Optimization with `dllhost.exe` enabled SYSTEM privileges. This bypassed typical protections like standard user privileges, preventing detection by URL filters or network security appliances.

The campaign included running data theft tools, then preparing for ransomware deployment with data encryption and potential leak threats, typical of Play's tactics.

Could the attack have been prevented?

Yes, the attack could have been prevented or its impact significantly reduced:

- Reducing service and process privileges, and isolating critical system components, could have limited SYSTEM-level attacks even post-exploitation.
- Blocking lateral movement between network segments and monitoring PowerShell and MSBuild activity could have detected early-stage reconnaissance and halted the spread.
- Alerts on CLFS exploitation, unusual credential-dumping activity, or use of certutil could have allowed response teams to intervene before ransomware deployment.

Sources:

- [Play ransomware exploited Windows logging flaw in zero-day attacks](#)
- [Ransomware Landscape May 2025: SafePay, DevMan Emerge as Major Threats](#)
- [Play \(Hacker group\)](#)

2. Malware

2.1. How many new malware variants are reported daily? Name your source with report name, year, and page number.

According to AV-TEST, over 450,000 new malicious programs or PUAs are registered worldwide each day. The global average is around 190,000 new malware attacks every second, with nearly 90% being phishing and social-engineering-based [avg.com](#).

Source: [AV-TEST Institute - Malware Statistics & Trends Report, 2025, p. 1](#)

2.2. What is a botnet? What is the most common operating system targeted by botnets? Name your source with report name, year, and page number.

Botnet Example: Mirai

- Predominantly targets Linux-based IoT devices (e.g. IP cameras, routers and etc.) ([Mirai \(malware\) - Wikipedia](#)).
- Used mainly for DDoS attacks, but also to infiltrate networks or deploy droppers.

Germany was the most targeted country for DDoS in Q1 2025. Over 20.5 million attacks occurred, with techniques like Mirai botnet amplifications commonly used ([Germany Most Targeted Country in Q1 2025 DDoS Attacks](#)).

2.3. What are typical attacker actions before executing ransomware? Name your source with report name, year, and page number.

Based on frameworks like the *BSI kill-chain model* and *Unit 42 Q1 2025 report*:

Initial Access:

- Phishing emails with malicious attachments or links. sometimes exploiting remote access flaws like unpatched RDP ([Top 10 Ransomware measures](#)).

Exploit and Privilege Escalation:

- Zero-day exploits e.g. CLFS vulnerability or credential-dumping tools .

Lateral Movement and Credential Dumping:

- Tools such as Mimikatz target LSASS exploring internal networks .

Data Exfiltration (Double Extortion):

- Sensitive data stolen before encryption and threatened to be made public ([Ransomware](#)).

Encryption and Ransom Demand:

- Common file extensions: `.encrypted` , `.play` , `.lock` and etc.
- Ransom demanded in Bitcoin or mobile top-ups ([Ransomware - Wikipedia](#)).

2.4. What protection mechanisms are recommended by IT-Grundschutz against malware? Name the title and ID of the specific requirements and state whether these are required for basic protection, standard protection, or for increased protection needs.

I've spent some time mapping the [BSI's Top-10 ransomware recommendations](#) onto the exact IT-Grundschutz controls, and here's a narrative that ties them together more naturally.

Basic Protection

One of the most important first steps is regular patching. According to OPS.1.1.3^[1], you need to keep track of all critical systems and install security updates as soon as possible after release, ideally within a few days (patches *MÜSSEN zeitnah nach Veröffentlichung bewertet und priorisiert werden*). For remote access, OPS.1.2.5^[2] emphasizes using secure VPN connections for maintenance access and multi-factor authentication for administrators (remote admin logins *SOLLTEN mit Mehr-Faktor-Verfahren geschützt werden*). Email is a common entry point for malware, so OPS.1.1.4^[3] recommends filtering emails for phishing and stripping dangerous content (like macros) before they reach users, for example, all email attachments *MÜSSEN auf Schadsoftware überprüft werden* and mail clients must not automatically execute active content. Finally, regular security awareness training helps people spot threats early. In fact, OPS.1.1.4.A7^[3-1] requires that users be educated about malware on a regular basis and follow basic rules (e.g. not opening files or links from untrusted sources).

Standard Protection

Once the basics are covered, you focus more on protecting the systems people use day-to-day. SYS.2.1.A6^[4] requires installing antivirus or modern EDR software on clients. These tools should not only scan for known viruses but also be configured so that users cannot disable them and that all file transfers are automatically scanned (the entire client's data *MUSS regelmäßig auf Schadsoftware geprüft werden*). With SYS.2.1.A16^[4-1], you can control which applications are allowed to run, anything not needed or not approved is removed or blocked (*Nicht benötigte Module, Programme, Dienste... SOLLTEN deaktiviert oder deinstalliert werden*). Then there's ORP.4.A2^[5], which follows the least-privilege principle: users and services are only given the permissions they absolutely need permissions *DÜRFEN NUR aufgrund des tatsächlichen Bedarfs... vergeben werden (Prinzip der geringsten Rechte)*. Administrative accounts should be kept separate and used only when necessary, with higher safeguards in place for those accounts.

Increased Protection

For critical environments or higher protection needs, NET.1.1.A33^[6] suggests dividing the network into tightly separated zones. In practice this means even if one segment is compromised by malware, the threat is contained and cannot easily spread laterally to the rest of the network. Lastly, CON.3.A15^[7] highlights how important robust backups are. Following the "3-2-1" rule, keep three copies of data on two different media, with at least one off-site, along with regular recovery tests (ensuring backups can be restored in an emergency), guarantees you can recover quickly if ransomware strikes. This backup concept is so vital that it is considered part of even basic protection, and it becomes absolutely critical for increased protection needs.

3. Vulnerability Management with CVE

The first issue i have found is CVE-2023-23923^[8]. This issue involves how someone could change another person's 'start page' in an app without needing special permissions. It seems the system didn't check thoroughly when users set their own dashboard or landing page, allowing an outsider to redirect you elsewhere. The score for this issue is 8.2, as it concerns keeping information private and preventing unauthorized changes to your settings. A workaround, if no update is available, is to limit access to preference editing through role overrides or to disable the feature using a local plugin override.

The second issue, CVE-2023-5540^[9], relates to a module called IMSCP that manages course materials. From what I understand, if someone is logged in, they could insert harmful code into their uploaded course package, which the server would execute. This issue scores 8.8 because it can disrupt server files, crash parts of the system, or leak user data, affecting privacy, data safety, and system uptime simultaneously. While waiting for an official update, the workaround is to disable the IMSCP module in the admin settings and monitor recent content uploads to ensure no one is sneaking in suspicious package files.

Lastly, there's CVE-2023-35133^[10], which consists of two problems: one where someone can trick the system into executing unexpected database queries (SQL injection) and another where they can make the server access internal resources it shouldn't (SSRF). This issue has a score of 7.5. It focuses on protecting the database from tampering and preventing outsiders from exploring the network. As a temporary solution, it is advised to turn off vulnerable services, like the MNet connection, and use firewall rules to block any unusual outgoing requests from the server until a patch is released.



1. [OPS.1.1.3 Patch- und Änderungsmanagement](#) ↩
2. [OPS.1.2.5 Fernwartung](#) ↩
3. [OPS.1.1.4 Schutz vor Schadprogrammen](#) ↩ ↩
4. [SYS.2.1 Allgemeiner Client](#) ↩ ↩
5. [ORP.4 Identitäts- und Berechtigungsmanagement](#) ↩
6. [NET.1.1 Netzarchitektur und -design](#) ↩
7. [CON.3 Datensicherungskonzept](#) ↩
8. [CVE-2023-23923](#) ↩
9. [CVE-2023-5540](#) ↩
10. [CVE-2023-35133](#) ↩